

Kịch bản thuyết trình

Báo cáo thực tập doanh nghiệp

AI-ECDSA Digital Signature System

Đại học Khoa học Tự nhiên, ĐHQGHN (VNU-HUS) Chuyên ngành:
Toán ứng dụng và Tin học

Năm 2026

Tổng thời gian dự kiến: 13–17 phút | Cấu trúc: 6 phần chính

1 Mở đầu — Giới thiệu bản thân & Đặt vấn đề

Thời lượng: Khoảng 1–2 phút

Nói: "Kính chào thầy cô và các bạn. Em là Hoàng Xuân Đức, sinh viên ngành Toán ứng dụng và Tin học. Trong thời gian thực tập, em đã nghiên cứu và xây dựng một hệ thống bảo mật kết hợp giữa mật mã học và trí tuệ nhân tạo — cụ thể là hệ thống Chữ ký số dựa trên đường cong Elliptic, tích hợp AI phát hiện IP nghi vấn tự động."

Dẫn vào vấn đề: "Hàng ngày có hàng tỷ giao dịch điện tử diễn ra — chuyển tiền, ký hợp đồng, xác nhận danh tính. Câu hỏi đặt ra là: làm sao biết tài liệu đó không bị giả mạo? Và làm sao ngăn kẻ xấu tấn công liên tục vào hệ thống? Đây chính là bài toán em giải quyết trong đề tài này."

Mẹo: Nhìn vào hội đồng, giọng tự tin, không đọc slide. Câu dẫn vào vấn đề là quan trọng nhất — tạo sự tò mò ngay từ đầu.

2 Lý thuyết nền — Đường cong Elliptic là gì?

Thời lượng: Khoảng 2–3 phút

- Giải thích ngắn:** Đường cong Elliptic là một phương trình toán học đặc biệt tạo ra bài toán cực kỳ khó giải ngược — đây là nền tảng bảo mật.
- So sánh trực quan:** RSA cần khóa 3072 bit để an toàn, tương đương với ECC chỉ cần 256 bit — tức là nhanh hơn và nhẹ hơn nhiều lần.
- Ứng dụng thực tế:** Bitcoin, TLS/HTTPS, chữ ký số chính phủ — đều dùng ECC.

Ví dụ dễ hiểu để nói: "Hình dung đường cong Elliptic như một mê cung — đi từ A đến B rất dễ, nhưng nếu ai đó chỉ biết B thì tìm ngược ra A gần như không thể. Khóa riêng là đường đi, khóa công khai là điểm đến."

Lưu ý: Đừng đọc công thức toán học lên màn hình — hội đồng không cần. Chỉ cần nêu ý tưởng cốt lõi: *để tính một chiều, không thể đảo ngược.*

3 Chức năng 1 & 2 — Chữ ký số + Mã hóa ElGamal

Thời lượng: Khoảng 3-4 phút

- **ECDSA:** Alice ký bằng khóa riêng → Bob xác thực bằng khóa công khai. Nội dung thay đổi dù 1 ký tự → chữ ký hỏng ngay. Không ai giả mạo được vì không có khóa riêng của Alice.
- **ECGDSA:** Biến thể tối ưu tính nghịch đảo khi tạo khóa thay vì khi ký → nhanh hơn khi ký nhiều tài liệu liên tiếp.
- **EC ElGamal:** Alice mã hóa tin nhắn bằng khóa công khai của Bob → chỉ Bob giải mã được. Hacker chặn gói tin cũng vô dụng.

Lúc này mở demo app: "Em xin phép demo trực tiếp — em chọn đường cong secp256r1, tạo cặp khóa, nhập văn bản, ký và xác thực. Hội đồng có thể thấy kết quả HỢP LỆ xuất hiện sau chưa đầy 100ms."

Demo trực tiếp tab "Chữ ký số" trên app: Ký "Tôi xác nhận báo cáo này" và xác thực. Sau khi xác thực thành công, thử sửa 1 chữ trong nội dung rồi xác thực lại — kết quả **KHÔNG HỢP LỆ** sẽ gây ấn tượng mạnh với hội đồng.

4 Phần AI — Trái tim của đề tài

*Thời lượng: Khoảng 4-5 phút — **Phần quan trọng nhất***

Hệ thống bảo vệ 3 lớp:

- **Lớp 1 (Whitelist):** IP tin cậy → luôn được đi qua, không kiểm tra gì thêm. Ví dụ: máy chủ nội bộ của công ty.
- **Lớp 2 (Hard Rules):** Luật cứng — gửi hơn 60 request/phút, hoặc thất bại hơn 80%, hoặc gửi 10 request trong 10 giây → chặn ngay lập tức, không cần AI.
- **Lớp 3 (Isolation Forest AI):** Model tự học từ 3.150 mẫu traffic. Phân tích 7 đặc trưng hành vi của mỗi IP — nếu điểm bất thường vượt ngưỡng → cảnh báo hoặc chặn tự động.

Giải thích AI đơn giản: "Isolation Forest hoạt động như thế này — hệ thống học cách traffic bình thường trông như thế nào. Khi có IP hành xử khác lạ — gửi quá nhiều, toàn thất bại, hoặc vào lúc bất thường — model cho điểm bất thường cao và tự động kích hoạt cảnh báo. Không cần con người giám sát 24/7."

7 đặc trưng AI theo dõi: tốc độ request, tỉ lệ thất bại, số loại message, giờ trong ngày, IP mới hay cũ, khoảng cách giữa 2 request, và burst flag (bùng phát đột ngột).
Demo tab "AI IP Guardian": Bấm "Mô phỏng tấn công", quan sát IP bị chặn sau vài chục request. Nhấn mạnh rằng hệ thống **tự động**, không cần can thiệp thủ công.

5 Kết quả thực nghiệm & Đánh giá

Thời lượng: Khoảng 2 phút

- Tất cả đường cong SEC2 (secp112r1 đến secp521r1) đều verify đúng 100% sau khi sửa lỗi tham số.
- Thời gian ký: từ 3ms (112-bit) đến 188ms (521-bit) — phù hợp ứng dụng thực tế.
- AI Guardian phát hiện tấn công rate trong vòng 65 request — dưới 1 phút kể từ khi tấn công bắt đầu.
- Sử dụng CSPRNG (`secrets` module) thay PRNG — đảm bảo khóa ngẫu nhiên an toàn mật mã học.

Nói: "Qua thực nghiệm, em nhận thấy sự đánh đổi rõ ràng giữa bảo mật và hiệu năng — đường cong càng nhiều bit thì càng an toàn nhưng tốn thời gian hơn. Với ứng dụng thực tế thông thường, secp256r1 là lựa chọn cân bằng tốt nhất — đây cũng là curve Bitcoin và HTTPS đang dùng."

6 Kết luận & Hướng phát triển

Thời lượng: Khoảng 1-2 phút

- **Đã đạt được:** Cài đặt thành công 3 thuật toán (ECDSA, ECGDSA, ElGamal), tích hợp AI 3 lớp, giao diện hoàn chỉnh, đã fix lỗi curve nghiêm trọng.
- **Hướng phát triển:** Tích hợp vào web thực (Flask/FastAPI), lưu blocked IP vào database qua restart, retrain AI bằng traffic thực, mở rộng sang ký file PDF.

Câu kết: "Đề tài này giúp em hiểu sâu về mật mã học hiện đại và cách ứng dụng AI vào bài toán bảo mật thực tế. Em tin rằng sự kết hợp giữa toán học và trí tuệ nhân tạo là hướng đi quan trọng cho an toàn thông tin trong tương lai. Em xin cảm ơn thầy cô và rất mong nhận được góp ý để em hoàn thiện hơn."

Chuẩn bị sẵn Q&A (3 câu hỏi hội đồng hay hỏi)

1. "Isolation Forest khác gì so với các thuật toán AI khác?"

→ *Trả lời:* "Isolation Forest là thuật toán học không giám sát — không cần dữ liệu có nhãn 'tấn công' hay 'bình thường'. Nó hoạt động bằng cách phát hiện điểm dữ liệu bất thường vì chúng dễ bị cô lập hơn. Phù hợp với bài toán bảo mật vì dữ liệu tấn công thực tế rất hiếm và khó có nhãn."

2. "Tại sao dùng đường cong Elliptic thay vì RSA?"

→ *Trả lời:* "ECC cho mức bảo mật tương đương RSA nhưng khóa ngắn hơn nhiều lần — RSA 3072 bit tương đương ECC 256 bit. Điều này có nghĩa là tính toán nhanh hơn, tiêu thụ ít tài nguyên hơn — rất quan trọng với thiết bị cấu hình giới hạn hay IoT."

3. "Hệ thống này có thể triển khai thực tế không?"

→ *Trả lời:* "Hoàn toàn có thể. Phần crypto đã dùng CSPRNG chuẩn mật mã học. Để production cần thêm: tích hợp middleware HTTP, lưu trạng thái block vào Redis/database để không mất khi restart, và retrain AI model định kỳ bằng traffic thực. Đây là hướng phát triển em đã đề xuất trong kết luận."